Cyber Threat Intelligence for SOC L1 Analysts

The modern Security Operations Centre (SOC) is a noisy place. Dashboards blink, telemetry streams in by the gigabyte, and the clock always ticks toward the subsequent potential breach. At the front of this controlled chaos sits the Level 1 analyst - the first human touchpoint for every suspicious ping, pop-up, or packet. This room seeks to translate the sometimes abstract discipline of Cyber Threat Intelligence (CTI) into everyday tasks: enriching indicators, triaging alerts, and turning raw data into the stories that matter.

The goal is to move learners from "I recognise an IP address" to "I recognise *why* this IP address spells trouble—and I can prove it" by achieving the following objectives:

Understand what threat intelligence is and why it matters to SOC analysts.
Know about the threat intelligence lifecycle and the indicators to look for.
Familiarise yourself with intelligence sharing using feeds and platforms.

A junior analyst logs in for their shift and finds two hundred fresh alerts waiting—everything from benign network scans to a PowerShell beacon that feels out of place. The ticket queue does not politely pace itself; it demands quick, confident decisions. This is where CTI earns its keep.

Threat intelligence provides the context that helps an analyst decide which of those two hundred alerts represents genuine danger. With reliable context, the SOC spends energy on the right issues and sleeps better when the dashboards are finally calm.

In concrete terms, CTI seeks to answer three essential questions:

Who, or what, is on the other end of this alert indicator?
What was their behaviour in the past?
How does my organisation respond, and what should I do about it right now?
When these questions are addressed early—preferably within minutes—an L1 analyst buys precious time downstream for the incident-response (IR) team. CTI is therefore not the exclusive domain of intel specialists; it is a front-line tool that elevates SOC triage from guesswork to calculated action.

From Raw Data to Usable Intelligence

Information security literature distinguishes **data, information**, and **intelligence**, yet the three terms often blur in daily conversation. Making them explicit clarifies an analyst's objective.

Layer	Definition	Alert-queue example	SOC L1 action
Data	An unprocessed observable	`45.155.205.3 :443`	Capture the artefact.
Information	Data plus factual annotation	*IP registered to Hetzner, first seen 2023-07-14*	Record attributes.
Intelligence	Analysed information that answers *so-what*	*IP belongs to the current BumbleBee C2; block immediately*	Escalate or suppress.

A Level 1 analyst is responsible for making the artefacts usable and enriching them until they qualify as intelligence, or demonstrating that they never will. That push is enacted through **enrichment**: rapid, methodical lookups of public, commercial, and internal sources that shed light on origin, behaviour, and relevance.

During the ascent of data to intelligence, three more labels become paramount for analysts to know.

Indicator of Compromise (IOC): Evidence of a breach, such as a C2 address in the logs.
Indicator of Attack (IOA): A malicious action, such as PowerShell launching an unknown service, is underway.
Tactics, Techniques, and Procedures (TTP): An adversary's detailed methodologies expressed in MITRE ATT&CK IDs and descriptions.

Indicator Types Essential to First-Line Triage

Every artefact demands a tailored enrichment path. Memorising tools is less important than recognising what kind of indicator the alert supplies and knowing where to look. Below, we have a table showing the types of indicators we need to be aware of, with examples:

Indicator	Example	First Resources	Associated IOA or TTP Examples
IPv4 / IPv6	`45.155.205.3`	• WHOIS (ASN, allocation date) · VirusTotal Relations· Shodan banner scan	IOA: Repeated SSH failures TTP: `T1110.003`Password Guessing
Domain / FQDN	`malicious-updates[.]net`	• WHOIS age · RiskIQ or SecurityTrails passive-DNS · urlscan.io	IOA: surge of DNS queries to a 24-hour-old domain
URL	`hxxp://malicious-updates[.]net/login`	• URLhaus reputation · urlscan.io behaviour graph · Any.Run dynamic run (network off)	IOA: Browser POST to /gateway.php with payload
File hash	`e99a18c428cb38d5…`	• VirusTotal static & dynamic · Hybrid-Analysis · MalShare corpus	TTP: T1055 Process Injection into regsvr32.exe
E-mail address	`billing@evil-corp.com`	• MXToolbox header analysis • Have I Been Pwned	IOA: SPF failure plus recent domain registration
Local artefact	`HKCU\Software\Run\updater.exe`	• Sigma rules · EDR prevalence query · Vendor knowledge bas	TTP: T1060.001 Registry Run Keys

Actionable tip. Maintain a browser bookmark folder or a SIEM launcher panel that opens your preferred look-ups with the highlighted indicator pre-populated. The thirty seconds saved per alert compound into hours over a month.

Feeds, Platforms, and Why the Distinction Matters

Most SOCs do not build or have intelligence in-house. The insights must be integrated and ingested from reliable sources.

Feed: A scheduled stream of indicators, usually delivered in various formats such as CSV, JSON, STIX, or through TAXII. Over-ingesting feeds without curation drowns analysts in false positives and erodes trust in the programme.

Platform: A structured repository that stores indicators, tracks enrichment, maps relationships, and enforces sharing permissions. MISP and OpenCTI are leading open-source examples.

Sound CTI practice introduces feeds gradually, confirms they align with the organisation's threat model, and promotes them into the platform only after measuring actionability. The platform then becomes the single source of truth—an analyst queries it first, ensuring biographies of indicators evolve rather than fork.

Sources of Cyber Threat Intelligence

Intelligence is only as trustworthy as its source, for it drives credibility and steers legal review if an IOC later triggers business disruption. As an analyst, you must know and note where each indicator originated.

There are four broad sources that you will come across in your practice:

Internal telemetry: SIEM logs, EDR detections, phishing-mailbox submissions provide the highest immediate relevance.
Commercial services: Vendor premium feeds, paid sandboxes**,** and closed-source analytics. These provide high fidelity, but may have export and sharing limits based on licensing.
Open-source intelligence (OSINT): AbuseIPDB, URLhaus, public blogs with IOCs, and academic research. Before applying, information from these sources will need to be cross-confirmed.
Communities & ISACs: Sector-specific lists marked with labels and rich context (e.g., FS-ISAC)
Threat Intelligence Classifications

Threat intelligence is geared towards understanding the relationship between your operational environment and your adversary. With this in mind, we can break down threat intel into the following classifications:

Strategic intel: High-level intelligence that looks into the organisation's threat landscape and maps out the risk areas based on trends, patterns and emerging threats that may impact business decisions. An example is an annual ransomware trends report predicting a shift to data-wiping extortion in healthcare.

Tactical intel: Assessments of adversaries' behaviours through analysis of tactics, techniques, and procedures (TTPs). This can be in the form of Advisory notes, such as detailing new T1059.005 (Visual Basic) abuse in malspam.

Operational intel: Campaign-specific details about the motives and intent to perform an attack. This is useful for understanding the critical assets available in the organisation (people, processes, and technologies) that may be targeted.

Technical intel: Atomic indicators and artefacts such as IPs and hashes related to an attack.

L1 analysts will escalate many Technical IOCs, observe and document Tactical IOAs, and identify patterns that feed Operational reporting.

CTI LIFE CYCLE

Cyber Threat Intelligence follows a six-phase intelligence lifecycle that transforms raw data into contextualised and action-oriented insights geared towards triaging security incidents. We shall look at this lifecycle as a narrative that follows a single SOC Level 1 analyst, Alex, as they weave CTI into a routine defence objective: protecting TryHatMe's production database.

Before we look into the lifecycle, various concepts are helpful to understand when working with threat intelligence.

Traffic Light Protocol (TLP)—A Primer for Proper Sharing

The **Traffic Light Protocol** is a four-colour labelling scheme defined by FIRST.org that governs how widely intel may be shared. These labels can be summarised in the following table:

TLP label	Sharing boundary	Typical SOC L1 behaviour
TLP: CLEAR	No restriction	Post to the internal wiki or platform.
TLP: GREEN	Share with peer community but not publicly	Upload to MISP/Slack workspace restricted to partner SOCs.
TLP: AMBER	Organisation-wide, external sharing only with need-to-know clients	Keep within the company CTI platform; reference, do not copy, in tickets.
TLP: RED	Named recipients only	Store in an encrypted note; do not post to the ticketing system without clearance.

While investigating breaches, a Level 1 analyst ensures that an IOC's TLP label—if provided—travels with the indicator into any platform or triage note. Violating the label can breach contractual obligations and erode trust with intelligence partners.

Intel Formats

Analysts encounter intelligence in various formats or protocols. Once they have gathered intel, they are responsible for sharing and updating other analysts on new findings about attack techniques. One format in which threat intel can be found is Structured Threat Information Expression (**STIX).** This JSON schema was developed to describe and specify threat indicators, relationships, and context in a machine-readable form.

We can now look into the CTI lifecycle with a real-world scenario.

Scenario Premise

TryHatMe Corp holds sensitive customer data in a PostgreSQL server in a segmented subnet. The server is fronted by a next-generation firewall (NGFW) and monitored on-host by an Endpoint Detection and Response (EDR) agent. Senior management has asked the SOC to "bring in cyber-threat intelligence" so that the controls react rapidly to emerging threats. The morning-shift L1 analyst, Alex, is assigned to build and exercise that workflow.

Step 1: Direction – Defining the Mission

Alex begins in a brief planning meeting with the CTI lead and the database administrator. Together, they translate the broad mandate into an intelligence requirement:

Primary asset. The PostgreSQL production database.

Business risk. Data breach fines under GDPR and loss of customer trust.

Available controls. NGFW is capable of IP- and domain-based blocking; EDR can quarantine files by hash.

Initial CTI goal. Use threat-feed indicators to:

Block or alert on suspicious IP addresses at the firewall, and
Detect known malicious file hashes at the EDR layer.
Alex constructs two measurable questions that will steer subsequent collection and analysis:

Q1 Which external IP addresses and domains are currently used to exploit PostgreSQL services or exfiltrate database records?

Q2 Which malware families targeting PostgreSQL drivers or credentials are active this week, and what are their file hashes?

The answers to Q1 and Q2 will become success criteria in later feedback.

Step 2: Collection – Assembling the Raw Material

Guided by the questions, Alex gathers intelligence from four sources:

Source	Rationale	Example artefacts collected
Commercial feed from the NGFW vendor	Tailored to the same firewall models, high-fidelity	37 IPv4 addresses flagged as database-exfil C2 in the last 24 h
Open-source project *AbuseIPDB* filtered by tag *PostgreSQL-brute-force*	Rapid, community-driven updates	15 IP addresses, four domains
The Malware Information Sharing Platform (MISP) is internal to the company	Historical view of incidents	2 SHA-256 hashes of PgSQL credential stealers
Vendor threat report released this week	Strategic insight distilled into technical IOCs	1 new malware hash, 3 C2 domains

Alex exports each feed in STIX or CSV, then stores a dated copy in the SOC's "raw-intel" S3 bucket, ensuring reproducibility.

Step 3: Processing – Normalising and Correlating the Data

Raw feeds never align perfectly, and artefacts may arrive in mixed formats. To correct this, threat intel will need to be normalised and correlated. Normalising ensures threat data from various sources is standardised into a standard format for consistent analysis. Correlation involves identifying connections and links between data from different sources and threats. It can also help identify contradictions, such as having a benign tag in one's history versus a malicious label in new data today.

For Alex, processing threat intel will involve executing scheduled Python scripts that:

Normalises indicator syntax such as having IPv6 addresses compressed, domains in lowercase or stripping off IP subnet masks.

Correlates and deduplicates against the platform's existing indicator table.

Tag each entry with source, date, and TLP label.

Converts the final set of intel into two action files, such as:

firewall_blocklist.csv, a firewall-ready CSV that covers the indicator, action, and comments
edr_hash_rules.yar, an EDR YARA-rule file for hash blocking.

During processing, Alex spots a collision: one IP address appears in the NGFW feed labelled as `TLP: AMBER` and AbuseIPDB labels it as `TLP: CLEAR`. Because the stricter TLP prevails, the combined record inherits `TLP: AMBER`. This prevents inadvertent disclosure if the list is later shared.

Step 4: Analysis – Turning Information Into Judgement

Blocking every indicator or artefact suspected of being malicious may create room for false positives. Alex would need to evaluate the relevance and matching between the intel gathered and the current status of the investigation. This results in providing answers to the questions in Phase 1:

Firewall indicators (Q1).
Cross-check: A Splunk query over the previous 30 days shows one of the NGFW IPs attempting but failing to open TCP 5432 against the production subnet. That event validates the indicator's applicability.

Hash indicators (Q2).
Reverse-search: OpenCTI links the new hash to the *PgSteal* malware family; Any.Run sandbox analysis demonstrates credential-dump behaviour. Because the organisation uses exactly the named ODBC driver, the hash is marked as high priority, and relevance is confirmed.
Alex grades each indicator:

Confidence	Source agreement	Local sightings	Action
High	Same IOC in ≥2 sources	≥1 local attempt	Immediate block
Medium	Single trusted source	No local hits	Alert-only
Low	OSINT only	No context	Monitor for 14 days

Seven IP addresses and one hash meet the *high* bar; the rest are queued as *medium* and set for monitoring.

Step 5: Dissemination – Getting Intelligence to the Right Consumers

Unused threat intelligence becomes shelfware. Alex delivers tailored output:

Stakeholder	Format	Why do they need it
Firewall team	CSV upload + change-ticket	They own the block rules; the ticket is to document risk and indicator TLP
Endpoint team	YARA rule set in the EDR console	To load rules into the policy
CTI platform	Indicator objects with full tags	Keeps history of artefacts, supports future correlations, and honours TLP
Management	200-word summary in weekly cyber-risk memo	The report shows the return on investment for the process

By tailoring depth to the audience, Alex ensures that each consumer receives only the detail required to act, nothing more and nothing less.

Step 6: Feedback – Measuring and Refining the Cycle

Two weeks later, metrics and reports from the firewall and EDR reports show the progress of establishing an effective threat intelligence workflow:

KPI	Baseline	After the first cycle
Median dwell time of PgSQL brute-force IPs	48 h	0 h (pre-emptive block)
False-positive rate on new blocks	—	0 % (none revoked)

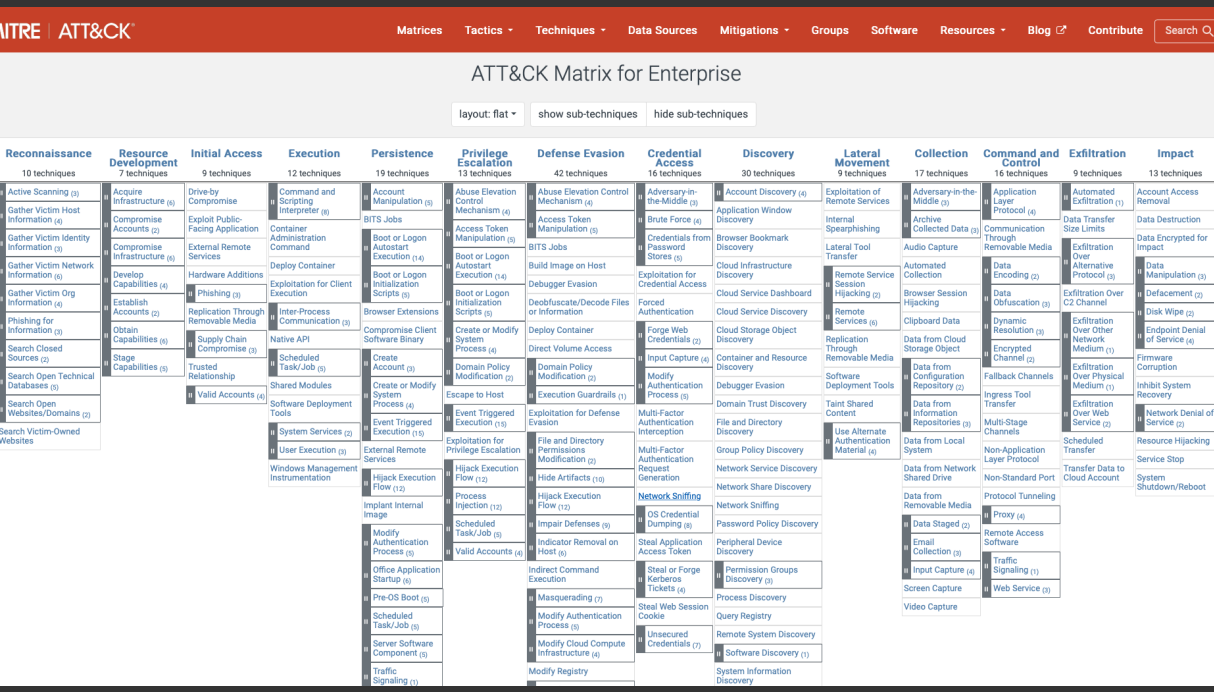
Because the outcome meets the initial direction objectives, management approves expansion: the next sprint will add other threat parameters, such as DNS tunnelling IOCs for the same asset group. Alex updates the direction document, closes the feedback loop, and schedules the second iteration.

CTI STANDARDS AND FRAMEWORKS

Standards and frameworks provide structures to rationalise the distribution and use of threat intel across industries. They also allow for common terminology, which helps in collaboration and communication. Here, we briefly look at some essential standards and frameworks commonly used.

MITRE ATT&CK

A malicious PowerShell command may look obvious, but your ticket needs a label everyone else recognises. MITRE's **ATT&CK** framework supplies that label. Each technique—*T1059.001 PowerShell*, *T1048.003 DNS tunnel*, and so on—acts as a Rosetta Stone between vendors, teammates, and auditors, providing knowledge about adversarial behaviour.



As an L1 analyst, you can use the matrix during an investigation in the following way:

Match the behaviour in the alert to a tactic/technique pair.
Write the ID in your triage note: "Observed **T1071.001** (web-based C2) against FINANCE-TRYHATME-00".
Hand the note to Level 2 or Incident Response; they instantly know which mitigations and threat-actor profiles apply.

MITRE D3FEND

If ATT&CK catalogues how adversaries attack, **D3FEND** catalogues how defenders respond. Each entry maps to defensive tactics such as Credential Hardening or Data Obfuscation_._

A case for this would look similar to this:

Your proxy raises a **T1048.003 DNS tunnel** alert.
Search D3FEND for the matching defensive technique: D3—NTDN DNS—request analysis. The page lists practical controls: block extensive TXT records and alert on uncommon query entropy.
Add the most feasible control to your "next actions" field; you have just supplied a mitigation, not only a diagnosis.

Cyber Kill Chain

The Cyber Kill Chain, developed by Lockheed Martin, breaks down adversary actions into steps. This breakdown helps analysts and defenders identify which stage-specific activities occurred when investigating an attack. The phases defined are shown in the image below.

Technique	Purpose	Examples
Reconnaissance	Obtain information about the victim and the tactics used for the attack.	Harvesting emails, OSINT, and social media, network scans
Weaponisation	Malware is engineered based on the needs and intentions of the attack.	Exploit with a backdoor, a malicious Office document
Delivery	Covers how the malware would be delivered to the victim's system.	Email, weblinks, USB
Exploitation	Breach the victim's system vulnerabilities to execute code and create scheduled jobs to establish persistence.	EternalBlue, Zero-Logon, etc.
Installation	Install malware and other tools to gain access to the victim's system.	Password dumping, backdoors, and remote access trojans
Command & Control	Remotely control the compromised system, deliver additional malware, move across valuable assets and elevate privileges.	Empire, Cobalt Strike, etc.
Actions on Objectives	Fulfil the intended goals for the attack: financial gain, corporate espionage, and data exfiltration.	Data encryption, ransomware, and public defacement

Over time, the kill chain has been expanded using other frameworks, such as ATT&CK, and a new Unified Kill Chain has been formulated.

CVEs, CVSS, and the NVD

A SOC queue contains almost as many vulnerability notifications as malware alerts. As an SOC L1 analyst, you must understand how to identify and organise vulnerability notifications.

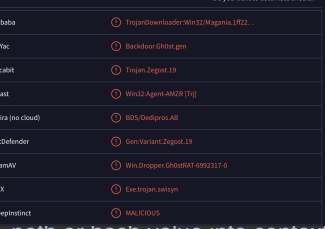
CVE (Common Vulnerabilities and Exposures) — provides a catalogue number for discovered vulnerabilities, e.g., *CVE-2023-4863*.
CVSS (Common Vulnerability Scoring System) — a 0–10 severity scale with temporal and environmental modifiers for vulnerabilities.
NVD (National Vulnerability Database) — the canonical repository that links CVE numbers to CVSS scores, exploits, and affected products.

Sharing and Processing Intel

We previously discussed platforms and feeds from which threat intelligence can be retrieved. When organisations publish fresh indicators, every peer that consumes and validates them strengthens the collective defence and feeds back improvements. This information looks to hinge on two standards: **STIX and TAXII.**

STIX: We mentioned STIX previously as the structured JSON schema for describing threat information.
TAXII: The Trusted Automated eXchange of Indicator Information is a set of secure APIs used to exchange threat intelligence in near real-time for detection, prevention, and mitigation of threats.
It supports two sharing models: **Collection**, which ensures threat intel is collected and hosted by a producer, and **Channel**, which publishes threat intel to users from a central server.
Sharing threat intelligence has its benefits, with near-real-time feeds shortening the gap between another organisation's incident and one's preventive procedures. Additionally, community contributions earn organisations reciprocal trust as valuable intelligence sources.

That said, not every indicator should be shared. Privacy laws, customer NDAs or internal competitive information may forbid disclosure, and sharing specific IOCs early can tip off adversaries that their campaign has been detected.



d Hash Threat Intel

queues and triaging. Every entry follows three essential
hash intelligence sits squarely in the *enrich* phase, transforming a lone path or hash value into contextual knowledge within your organisation about malicious artefacts that would be identified.

Learning Objectives

By completing this room, you will be able to:

Interpret suspicious filepaths and filenames using heuristics.
Generate and validate file hashes.
Leverage VirusTotal and MalwareBazaar to enrich newly observed binaries.
Extract behaviour from sandbox telemetry and map it to MITRE ATT&CK.

We've identified suspicious heuristics from the sample files through path and name analysis. The analysis is not conclusive, as attackers constantly rename files. We can tie the names back to the same binary through cryptographic fingerprinting through its file hash, especially SHA256 and MD5 hashes. File hashes uniquely identify files and malware, regardless of name changes. Attackers constantly rename their malware; hashes always provide an immutable and actionable way to identify it.

It is advisable to work with potentially malicious binaries in a separate, isolated environment.

We can generate and verify our file hash using the following commands:

Windows Commands

```
Command prompt: certutil -hashfile bl0gger.exe SHA256

PowerShell: Get-Filehash -Algorithm SHA256 bl0gger.exe
```

Linux Commands

```
ubuntu@tryhackme$ sha256sum bl0gger.exe
```

A few pointers as analysts when dealing with hashes:

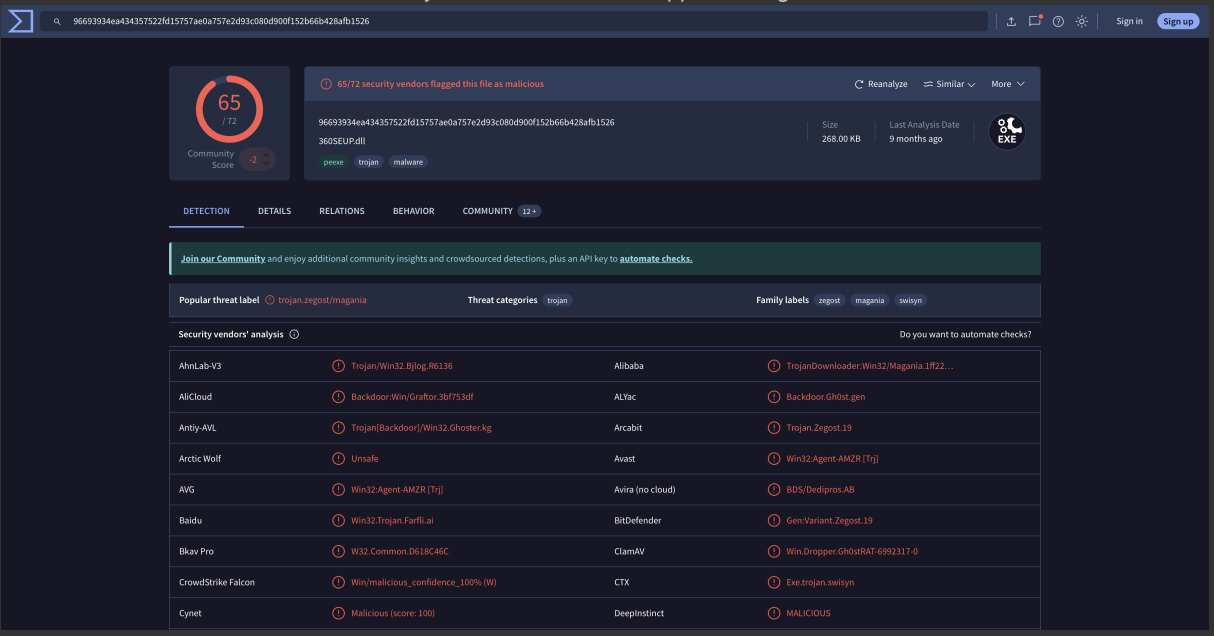
- Store the hashes in lowercase to avoid needless differences.
- Hash what matters in your investigation. For example, if the malware lives inside a zip file, hash both the archive and the extracted binary.
- Do not leave plain strings without the context of where and when you encountered them.
- Any byte change will change the resulting hash.

Analysis With VirusTotal

Using VirusTotal, we can obtain information about our file using the SHA256 hash. Navigate to the website, enter the hash in the search and observe the file's detection details.

There are several items from the search results that would be worth taking note of. These include:

Detection score: This represents a crowdsourced security verdict from various vendors displayed as a ratio. The higher the number, the higher the confidence threat.
Threat labels and categories: These are vendor-specific classifications of the threat, which help confirm the threat's attribution among vendors.
Detection rules: These are the technical signatures used by AV engines to identify threats. Typical classifications are YARA rules, Heuristic patterns, and behavioural triggers.
Properties: This is where the core metadata about the file is found, including the file type, size, and compiled timestamp.
Contained domains and IPs: This information covers the malware's network infrastructure.
Contained files: This section details any files embedded or dropped during the malware's execution.



We can break down the process above into granular steps that ensure VirusTotal becomes a tactical threat intelligence platform for the SOC to pivot towards actionable defence measures.

Section	Key Question	Red Flags	Analyst Considerations
Detection Score and Threat Labels	How many vendors detect this file as malicious?	Five or more solid vendors flag it Conflicting classifications (e.g., "Trojan" vs "PUA") No consensus among the top 3 vendors	New malware often has low initial detection Recheck after 24h for updated results Look at the classification of the malware family name or capability name
Upload Time	When was the file first submitted?	Uploaded seven days ago with more than 10 detections Sudden detection spike after days/weeks	Vendors need 48-72 hours for full analysis Historical detection growth indicates malware ageing
Signatures	Is the file properly signed?	Invalid/missing certificate Certificate issued to an unrelated entity	Even valid certs can be stolen/abused Check cert chain expiration dates
Properties	Are there anomalies in the file data?	Compile timestamp at odd hours (e.g., 3 AM) High entropy (>7.5) in non-media files	Some legitimate packers (UPX) increase entropy Compare with known-good versions
Relations	What infrastructure does the malware connect to?	Known-bad IPs in VirusTotal's graph DGA-like domains (e.g., xk8f92.xyz)	Legitimate CDNs may host malware Check IPs in Shodan for open ports
Behavioral	What post-execution actions occur?	Modifies critical registry keys Attempts process injection	Some admin tools modify registries legitimately Correlate with endpoint logs

Cross-Reference With MalwareBazaar

As the name suggests, MalwareBazaar(opens in new tab) is an all-in-one malware collection and analysis database. The project supports the following features:

Malware Samples Upload: Security analysts can upload their malware samples for analysis and build the intelligence database. This can be done through the browser or an API.
Malware Hunting: Hunting for malware samples is possible through various elements, such as :
Malware Family tagging: You will find files classified by their malware families. An example of this use is a file with only 5/70 detections on VirusTotal, but tagged as #IcedID in MalwareBazaar, should be treated as malicious.
YARA rule integration: Many submissions will include rules that detect related samples. As an analyst, you should take note of these rules to be added to the EDR/SIEM for future hunting.
Campaign attribution: Tags such as #TA551, which belong to a threat actor group, help link observed incidents to known adversaries. This can help identify coordinated attacks against an environment.
Sample Availability: Malware samples are available for download and analysis. Reanalysing samples in a sandbox is best practice, which we shall cover in the next task.

MalwareBazaar is a great tool for an analysis workflow that would be used to cross-reference VirusTotal results. One thing to be aware of is the tool's search syntax, which uses specific tags. For example, to search by SHA256 hash, the syntax is `sha256:<file_hash>`.

SANDBOX ANALYSIS

Dynamic Analysis for SOC

Static properties such as hashes, strings, and sections tell you identity. To understand the impact of malicious files, you need to execute them safely in a controlled environment. Sandboxes provide a disposable VM instrumented to capture every process, registry write, and network packet associated with the malware being investigated.

Security analysts will use sandboxes to do three things:

Confirm execution - if nothing happens, your alert might be a decoy.
Extract runtime IOCs - domains, mutexes, dropped payloads, feed hunts and detections.
Map to ATT&CK - most sandboxes auto-label behaviour with technique IDs, fast-tracking your report.
As an L1 analyst, you would use the sandboxes' lookup features to quickly identify information about an obtained hash, while senior analysts would perform the other sophisticated tasks.

Sandboxing Tools

The most widely used tools for detonating wild malware are **Hybrid Analysis** and **Joe Sandbox**, each with its distinct application:

Hybrid Analysis (HA) focuses on behaviour trees and a clean MITRE ATT&CK heatmap. It is suitable for a fast executive summary.
Joe Sandbox (JS): goes deep, covering system calls, strings, and memory dumps. Great for reverse engineers and detection engineers.

Analysing Hybrid Analysis Report

When we search using the file hash and analyse the generated report(opens in new tab) from Hybrid Analysis, we can confirm that the file is malicious, with a threat score of 100/100.

We are also provided with information about the file's risk behaviour and the ATT&CK Techniques the threat actor observed using.

HYBRID ANALYSIS | Sandbox | Quick Scans | File Collections | Resources | Request Info | IP, Domain, Hash...

2025-05-15_de30aa2610c11376251cba21a9323c83_agent-tesla_amadey_backswap_darkgate_elex_icedid_...

malicious

This report is generated from a file or URL submitted to this webservice on May 15th 2025 12:31:47 (UTC)
Guest System: Windows 10 64 bit, Professional, 10.0 (build 16299),
Report generated by Falcon Sandbox © Hybrid Analysis

Threat Score: 100/100
AV Detection: 88%
Labeled as: Win/malicious_confidence_100%
#BlackMoon #Discovery #windows-server-utility

Overview | Sample unavailable | Copy Sample SHA256 | Copy Sample Name/URL | Downloads | External Reports | Re-analyze | Hash Not Seen Before | No similar samples | Report False-Positive | Request Report Deletion

Post | Link | E-Mail

Incident Response
Indicators
File Details
Screenshots (5)
Hybrid Analysis (5)
Network Analysis
Extracted Strings
Extracted Files (48)
Notifications
Community (1)
Back to top

Incident Response

Risk Assessment

Spyware	Found a string that may be used as part of an injection method POSTs data to a webserver Sets a global windows hook to intercept mouse events
Stealer/Phishing	Tries to steal Mail credentials from registry
Persistence	Spawns a lot of processes Writes data to a remote process
Fingerprint	Queries kernel debugger information Queries process information Queries sensitive IE security settings Queries the internet cache settings (often used to hide footprints in index.dat or internet cache) Tries to steal Mail credentials from registry
Evasive	Marks file for deletion
Network	Calls an API typically used to create a HTTP or FTP session
Network Behavior	Contacts 5 domains and 6 hosts. View all details

MITRE ATT&CK™ Techniques Detection

This report has 310 indicators that were mapped to 130 attack techniques and 12 tactics. View all details

Additionally, we can gather all file details and information to inform our threat intelligence report. These details are vital for threat reporting, both internally and externally, including file compositions, imports, processes called, and network connections.

HYBRID ANALYSIS | Sandbox | Quick Scans | File Collections | Resources | Request Info | IP, Domain, Hash...

File Details

All Details: On

Incident Response
Indicators
File Details
File Metadata
File Sections
File Resources
File Data Directories
File Imports
Screenshots (5)
Hybrid Analysis (5)
Network Analysis
Extracted Strings
Extracted Files (48)
Notifications
Community (1)
Back to top

2025-05_15_de30aa2610c11376251cba21a9323c83_agent-tesla_amadey_backswap_darkgate_elex_icedid_rhadamanthys_smoke-loader

Filename	2025-05-15_de30aa2610c11376251cba21a9323c83_agent-tesla_amadey_backswap_darkgate_elex_icedid_rhadamanthys_smoke-loader
Size	2.6MiB (2695978 bytes)
Type	peexe executable
Description	PE32 executable (GUI) Intel 80386, for MS Windows, 4 sections
Architecture	WINDOWS
SHA256	2672b6688d7b32a90f9153d2ff607d6801e6cbde61f509ed36d0450745998d58
MD5	de30aa2610c11376251cba21a9323c83
SHA1	eff8ed1e41e81933909f201ccb1ca7461841684e
ssdeep	24576:5nWYXDaHMv6CorjqnyPQGzh0JONZejOuC+e4mOzrvxiI3ENyesg/jHLxQVIxX6L0:tI1vqjdPQRw/D4mizA0dizLrB51v1
imphash	0a16a06cf586b598d76b4843b67cf2de
authentihash	ca99ae4426d9c819ef930aed4823e0096f3f127ef7baf93319f0195ac159b02b
Compiler/Packer	Microsoft visual C++ 5.0

Resources

Language	ENGLISH
Icon	

Visualization

Input File (PortEx)

Entrypoint Preview

Instructions Count	30
Actions	Show Preview

Additional Static Data

Entrypoint	0x40cab0
Entrypoint Section	.text
ImageBase	0x400000
Subsystem	Windows Gui
Image File Characteris...	RELOCS_STRIPPED, EXECUTABLE_IMAGE, LINE_NUMS_STRIPPED, LOCAL_SYMS_STRIPPED, 32BIT_MACHINE
DLL Characteristics	
Major OS Version	4
Minor OS Version	0

Classification (TrID)

- 38.4% (.AX) DirectShow filter
- 22.2% (.OCX) Windows ActiveX control
- 10.9% (.CPL) Windows Control Panel Item (generic)
- 8.2% (.EXE) InstallShield setup
- 5.9% (.EXE) Win32 Executable MS Visual C++ (generic)

Sandboxing Limitations

While sandboxing is a powerful tool for malware analysis, it has critical limitations that SOC analysts must account for when performing threat intelligence. Blindly trusting sandbox results can lead to false negatives, missed detections, or incorrect conclusions.

These limitations include, but are not limited to, the following:

Sandbox Evasion Techniques Threat actors would design their payloads to detect and evade sandboxes, leading to false negatives. Some of the common evasion tactics used include:
Environment Awareness Checks: Malware checks for signs of virtualised/sandboxed environments
Anti-Debugging & Anti-Sandboxing Tricks: Malware conducts debugger detection and checks for unique hardware IDs.

Limited Execution Time & Coverage Most sandboxes terminate analysis after 2-5 minutes, which means multi-stage malware may not fully execute. Additionally, time-delayed attacks will evade detection. As previously covered, this would mean cross-referencing other threat intelligence resources.

Encrypted & Obfuscated Traffic Many sandboxes cannot decrypt SSL/TLS traffic, leading to blind spots. This may result in HTTPS C2 Traffic appearing with no payload visibility or the malware utilising DNS tunnelling to hide data in DNS queries

Fileless & Living-off-the-Land (LotL) Malware Some threats never touch disk, bypassing traditional sandbox analysis by employing PowerShell Attacks and WMI Persistence.

Congratulations on completing the room! Threat intelligence is integral to an SOC workflow that enriches unknown binaries encountered by threat alerts.

Key Takeaways

Validate evidence before analysis: confirm you have the exact binaries and hashes.
Analyse filepaths and filenames for quick context: Unusual storage locations, trusted software directories, and naming tricks highlight items that warrant deeper review.
Generate hashes early to pivot into external or internal knowledge bases.
Observe runtime behaviour in a controlled environment to confirm intent, extract network and persistence indicators, and map activity to recognised attack techniques.
Translate findings into a brief that lists indicators by type, summarises behaviour and provides proportionate recommendations supported by evidence.

IP and Domain Threat Intel

Security Operations runbooks still revolve around the process `verify → enrich → decide`, but when the alert is a lone IP address or domain, the enrichment phase looks different. Instead of hashes, we pivot on geolocation, ASNs, open-service footprints, and passive DNS to learn whether a connection is routine SaaS traffic or an adversary foothold beacon.

Learning Objectives

By the end of this room, you will be able to:

Understand IP and domain threat intelligence for a SOC.
Geolocate IPs and interpret their Autonomous System Numbers (ASNs).
Detect red-flag infrastructure via Shodan/Censys service banners.
Assess reputation with various tools.
Enrich domains with WHOIS age, DNS records, and certificate transparency.

Network-based threat intelligence is an essential aspect of modern cyber security defence. Examining IP addresses and domains from a threat intelligence perspective involves investigating beyond network connectivity to understand the malicious intent and capability behind the digital assets in a way that supports quick, safe triage for SOC L1 analysts.

Why DNS Matters in the SOC

Every time a user clicks a link or a system resolves a hostname, the Domain Name System (DNS) springs into action. DNS is the mechanism that converts human-friendly names like www.tryhackme.com into IP addresses that machines understand. Because of its central role in making the internet usable, DNS is also a favourite playground for attackers.

For SOC analysts, DNS is one of the richest early-warning datasets. Suspicious domains will appear in alerts long before a payload hash is known. Adversaries rapidly register, configure, and abandon domains to stay ahead of defences. Our job as analysts is to turn a raw domain into a contextual artefact: who owns it, what IPs it resolves to, how often it changes, and whether it behaves more like a normal content delivery network (CDN) or a throwaway setup.

Core DNS Records for Triage

When you enrich a domain, these are the records that matter most:

A / AAAA Records: Map the domain to IPv4 and IPv6 addresses. If you see several A records that hop between different networks, raise suspicion of rapid rotation. In practice, copy the A record from nslookup.io(opens in new tab) or dnschecker.org(opens in new tab) and follow with pasting the IP into VirusTotal for a quick read.

NS Records: Identify the nameservers controlling the domain. Unusual or recently changed NS entries can mark fresh set up. As L1 analysts, we should note the provider name rather than chasing low-level details.

MX Records: Define which servers handle email. Attackers may configure MX records to deliver phishing campaigns directly. If the alert relates to web browsing, just record whether MX exists.

TXT Records: Store SPF and DKIM rules or verification tags. Poorly configured or absent SPF can increase risk in mail cases.

SOA Record: Points to the zone's primary authority and often includes contact information. It will be worth noting the primary host and serial, which will support a basic ownership picture.

TTL (Time To Live): Tells resolvers how long to cache answers. Very low TTLs, seconds or minutes, can point to frequent changes, and should be treated as clues.

SOC Use Cases

Based on our scenario, the SIEM raises an alert pointing to the domain advanced-ip-sccanner[.]com. As L1 analysts, we need to enrich this artefact by gathering the above DNS records using tools such as nslookup.io(opens in new tab) or dnschecker.org.

Attack Techniques Using DNS

Fast Flux Hosting: Adversaries rotate many IPs quickly with short cache times to avoid simple blocks. We need to record and escalate when we identify a domain that resolves to changing IPs within a short period and across different providers.

CDN Abuse: Legitimate CDNs like Cloudflare or Akamai change IPs too, but done within their ASN ecosystem. If the A record points to a major CDN and other values are normal, take note and carry reputation and ownership checks,

Typosquatting: Domains like paypa1[.]com or micros0ft[.]net trick users visually. If a name looks like a brand clone, treat it as high risk and escalate it.

IDN (Internationalised Domain Names): Attackers exploit Unicode, creating look-alike domains. Decode Punycode, for example xn--ppaypal-3ya[.]com, and compare to known brands using simple online decoder.

SOC Analyst Workflow

At this stage, our workflow in the SOC could look as follows. Be mindful that this would vary depending on established organisational processes and practices.

Snapshot Current DNS: Capture A, NS, MX, TXT, SOA, and TTL values for the domain in question using a single page view and simple.

Basic Ownership Check: Use WHOIS to note registrat, creation date and contact pattern, which supports a light ownership picture of the ticket.

Interpret Patterns: Assess whether the DNS behaviour aligns with benign CDN activity or indicates malicious throwaway domain, noting down the details of the changing IPs.

Log Evidence: Save screenshots or JSON extracts DNS and reputation pages to the case file for audit and escalation.

Recommend Action: Based on findings, advise blocking if high risk, monitor if suspicious but inconclusive, or close if determined benign.

IP ENRICHMENT : GEOLOCATION & ANS

IP Enrichment Within the SOC

Most SIEM or EDR alerts contain at least one IP address. An IP address is ambiguous by itself: it could belong to a compromised router in a home office, a shared CDN edge, or a cloud service used by thousands of tenants. Without enrichment, we risk overreacting (blocking legitimate infrastructure) or underreacting (ignoring a real command-and-control server).

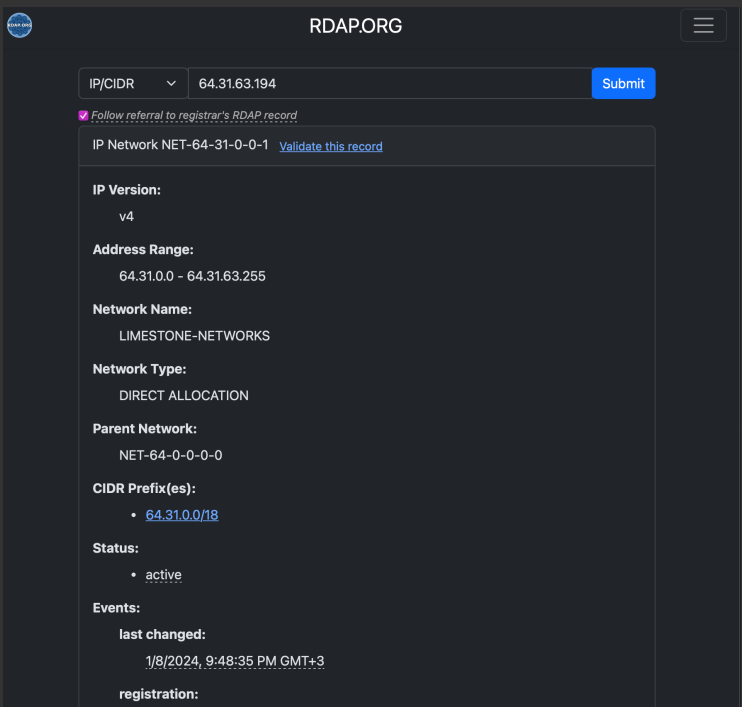
Enrichment is adding ownership, ASN (Autonomous System Number), geolocation, and service context to an IP so that our decision is evidence-driven. SOC Level 1 analysts must perform this consistently, since IPs are the most common indicators in alert queues.

The Role of RDAP

The **Registration Data Access Protocol (RDAP)** is the authoritative source for IP ownership. Unlike commercial GeoIP services or provider marketing pages, RDAP data is maintained by Regional Internet Registries (RIRs) such as RIPE NCC, ARIN, and APNIC. It tells us precisely who has been provided with the netblock.

From RDAP, we obtain:

NetRange: The range of addresses delegated.
Organisation: The registered holder (e.g., Amazon, Vodafone, TryHackMe).
Remarks: Often include whether the block is used for hosting, broadband, or mobile.
Abuse Contact: The official mailbox for incident reporting.
In our scenario, we can retrieve RDAP details on the IP address `64[.]31[.]63[.]194`.



If our alert points to suspicious traffic, we should pivot to the domain or certificate to narrow the scope. We should also preserve audit evidence of this data in reliable formats such as raw RDAP JSON, preventing reliance on potentially outdated secondary sources

Autonomous Systems and Heuristics

An **Autonomous System (AS)** is a collection of IP prefixes under a single organisation's control. Each AS is assigned a unique 16 or 32-bit number (ASN), only required for external communications. Looking at the ASN helps analysts assess the likely role of an IP.

Hosting ASNs: Many small netblocks, often with diverse tenants. Suspicious domains are frequently hosted here.
Residential ISPs: These have huge ranges covering millions of users. Alerts on these may indicate compromised home routers or consumer devices.
Cloud/CDN ASNs: Global anycast, dozens of prefixes, shared edges. Blocking whole ranges here causes collateral damage.
Some heuristic examples of ASN classification include:

AS32934 - Facebook/Meta: Traffic from here is based on the social media infrastructure. Malicious use may likely indicate an account issue, and not malicious hosting.
AS16509 - Amazon AWS: This would cover a massive cloud space, and attackers would often abuse it for short-lived servers. Blocking the entire ASN would be catastrophic, so we scope to the FQDN or narrow the CIDR.
AS124888 - Vodafone: This covers an ISP. Malicious activity would likely be from a compromised customer device.

Geolocation: Value and Limitations

GeoIP is widely used but often misunderstood. Tools like ipinfo.io(opens in new tab) and iplocation.net(opens in new tab) provide approximate country and city. However, it is worth observing that:

Country mismatches are common. CDN and cloud providers may register ranges in one country but host edges globally.
City-level accuracy is unreliable. SOC analysts should never justify a block based on a city.
Jurisdiction matters in legal escalations: legal teams may pursue takedown requests via the abuse contact if a host is located in a cooperative country.
Best practice: Record the country reported by at least two sources and note discrepancies. Treat this as a hint, not a fact.

SOC Analyst Workflow

At this stage, our workflow in the SOC could resemble the following, though it may vary depending on established organisational processes and practices.

Start with RDAP: Confirm netrange, org, ASN, and abuse contacts.
Add ASN Context: Check bgpview.io or ipinfo.io for ASN details and role.
Check Geolocation: Capture country from at least two sources. Record mismatches.
Look for rDNS Patterns: Reverse DNS can hint at hosting type (e.g., *[.]btcentralplus[.]com = UK broadband). Do not base decisions solely on rDNS.
Consult Internal Logs: Has this IP appeared in the last 30 days? If yes, in what context?
Classify Role: Hosting, residential, CDN, or cloud. Record reasoning.
Plan Outreach: If confirmed malicious and in a cooperative ASN, prepare a report for the abuse contact.

SERVICE EXPOSURE

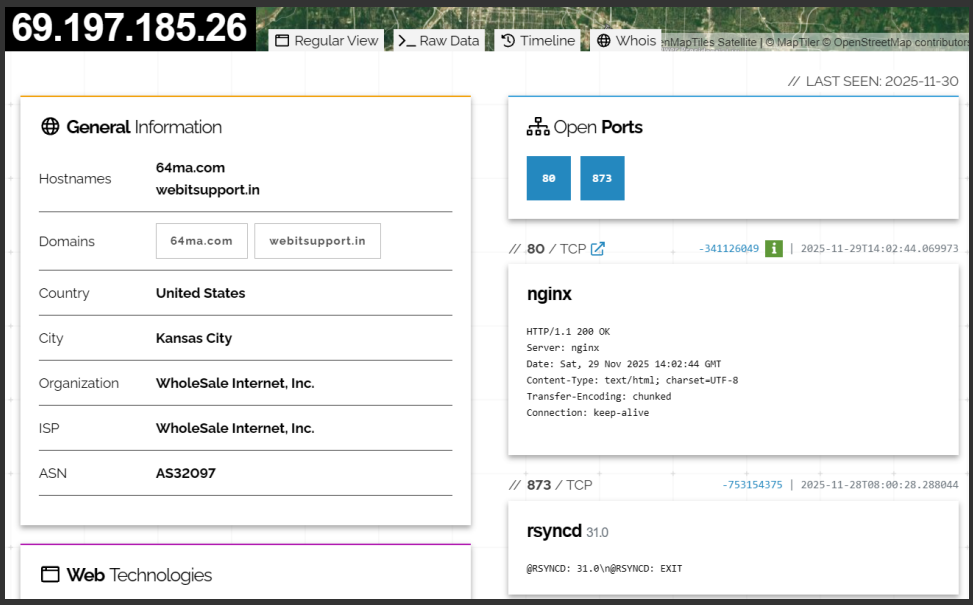
Services and Certificates

Looking at an IP or domain's location data also helps us understand its function. Exposed services provide information on the system's intent and potential blast radius if abused. For example, an IP with RDP exposed on port 3389 may be a target for a brute-force attack.

Shodan Reconnaissance

Shodan(opens in new tab) is a powerful reconnaissance tool for IP address analysis. By indexing internet-connected devices and services, Shodan provides detailed information about open ports, running services, and system configurations. Queries like `org:example[.]com` reveal all systems associated with specific organisations, while searches for specific software versions help identify vulnerable systems.

Let us look at the IP address from our flagged list, `69[.]197[.]185[.]26`. You can do it by visiting Shodan website and pasting the IP in plaintext in the search box:



From our search, we can extract information on:

Open Ports: This is the first fingerprint of exposure. On the screenshot above, both Nginx web sites and Rsync service can be targeted by threat actors.

Service Banners: These provide hints on server types and frameworks used. Additionally, software versions and cookies in RDP/HTTP banners can inform us about operator markers

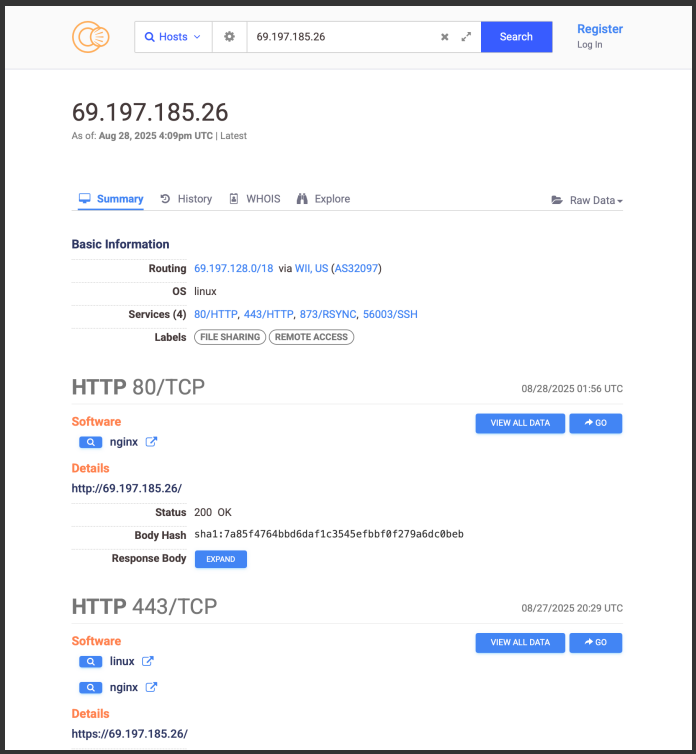
TLS Certificate Transparency

We can look at TLS certificate information using tools such as crt.sh(opens in new tab) as a gold mine for enrichment. Certificate Transparency logs every publicly trusted certificate. The key fields to look out for include:

Issuer: This field provides details on who signed the certificate. For example, Let's Encrypt is a common but neutral vendor. A self-signed certificate may be a sign of a hastily deployed system.
Validity Period: Short-lived certificates of up to 90 days are normal for usage. Analysts must look for bursts of reissued certificates and investigate suspected phishing infrastructure.
Subject Alternative Names: This provides details on the domains covered by the certificate.

Censys Search

Censys.io(opens in new tab) can be a good alternative to Shodan for blue teams, as it shows exposed services even on non-standard ports and provides some advanced search capabilities. However, note that some of these features may require an account on the platform. For example, below you may see that Censys found yet another exposed port, `56003/SSH`.



SOC Analyst Workflow

At this stage, our workflow in the SOC could resemble the following, though it may vary depending on established organisational processes and practices.

Check Shodan/Censys banners: Identify exposed services and possible misconfigurations.
Review TLS certificates: Ensure to record issuer, SANs, and validity period.
Look for anomalies: Instances of multiple SANs, brand look-alikes or sudden bursts of issuance.
Pivot: Utilise the certificate or banner artefacts to uncover related infrastructure.
Assess blast radius:
RDP/SSH on residential ASN → shows a likelihood of a compromised endpoint.
TLS with many unrelated SANs on CDN ASN → shared infrastructure, avoid IP block.
Self-signed TLS on small ranges → shows likelihood of attacker panels or proxies.

OPERATIONAL INTEGRATION

Analysts need to understand how to turn intelligence into safe action. The risk here is missing an attack and breaking legitimate business applications through overbroad controls. We avoid that outcome by being precise and planning for expiry and review.

Safe Integration Patterns

Prefer hostnames when domains are stable: IPs change frequently on CDNs or anycast platforms.
Use DNS response policy zones, proxy categories, or SNI filtering.
Use narrow IPs for single-purpose VPS: When an address is clearly dedicated to staging or command and control, a /32 block is effective with minimal blast radius.
Set expiry on blocks: Infrastructure is reused and recycled. A seven-day or fourteen-day expiry, with auto-renew on re-observation, prevents permanent collateral damage.
Document evidence in SOAR: Include screenshots, RDAP events, certificate excerpts, and reasoning.

Geofencing Cautions

Country blocks feel attractive; however, they often break real workflows. Colleagues travel, third-party services use overseas PoPs, and some vendors terminate TLS in unexpected regions. We treat geolocation as enrichment to raise priority, not as a primary control, unless the risk decision has been reviewed with the business and tested.

Cloud and Large Provider Pitfalls

Do not add entire CDN IP ranges like Amazon or Microsoft to a deny list. These providers reuse IPs across many customers and services. Blocking a large cloud block will eventually impact business systems. If a malicious hostname is served from a cloud edge network, take action at the domain or path level and consider vendor abuse processes.

Legal and Provider Considerations

Knowing the provider and country informs whether evidence preservation or rapid takedown is achievable. Some providers have strong abuse desks and comply quickly with requests. Others are slower or operate under legal frameworks that make urgent actions difficult. Record the RIR ownership and the abuse contacts gathered from RDAP for escalation paths.

From Data to Decision

We can now follow a simple playbook to make informed decisions when investigating an indicator.

Verify: Confirm that the indicator appears in our telemetry and is relevant to our environment.
Enrich: Collect geolocation, ASN, banners, certificates, reputation, and history.
Score: Apply the confidence matrix and record the rationale.
Decide: Block, monitor, or allow. Prefer precise controls, add expiry, and document.
Hunt and notify: Search for related indicators, inform stakeholders, and create follow-up tasks